Разбор APK: Фонбет - ставки на спорт

Разработчик: FNBT_Developers · Package: com.fonbet.all.sport.and.stavki.app · versionName 1.0 (versionCode 1)
Название в Play: «Фонбет - ставки на спорт». application-label внутри APK: «Фонбет» (строка app_name).

SDK / стек

Параметр	Значение
Название приложения	Фонбет - ставки на спорт (в карточке Play); application-label в APK — Фонбет
Android Gradle Plugin	8.2.2
minSdk	24
targetSdk	35
Kotlin	да, 2.1.0
Web View	да
Custom Tabs	да
Рекламные сети	нет
Аналитика	AppMetrica (Yandex), Firebase Cloud Messaging, Firebase Installations, Google DataTransport (CCT), Google Play Services Ads Identifier, Google Play Services AppSet
Permissions	android.permission.INTERNET, android.permission.ACCESS_NETWORK_STATE, android.permission.POST_NOTIFICATIONS, android.permission.WAKE_LOCK, com.google.android.c2dm.permission.RECEIVE, com.fonbet.all.sport.and.stavki.app.DYNAMIC_RECEIVER_NOT_EXPORTED_PERMISSION, com.google.android.finsky.permission.BIND_GET_INSTALL_REFERRER_SERVICE, com.android.vending.CHECK_LICENSE
Libraries	androidx.appcompat, androidx.core, androidx.activity, androidx.fragment, androidx.lifecycle, androidx.navigation (fragment, ui, runtime, compose), androidx.room (runtime, ktx), androidx.sqlite, androidx.recyclerview, androidx.viewpager2, androidx.constraintlayout, androidx.coordinatorlayout, androidx.drawerlayout, androidx.preference, androidx.browser (Custom Tabs), androidx.startup, androidx.profileinstaller, androidx.emoji2, androidx.window, androidx.databinding (viewbinding), androidx.compose (ui, runtime, foundation, material), androidx.hilt (navigation), com.google.android.material, com.google.dagger (Dagger, Hilt Android), retrofit2 + converter-gson, okhttp3, okio, com.google.gson, com.bumptech.glide, io.ktor (client, http, serialization, websocket, sse), io.github.jan.supabase (supabase-kt 3.0.3: postgrest, auth, serializer), kotlinx.serialization, kotlinx.coroutines (core, android, play-services, slf4j), com.russhwolf.settings (multiplatform-settings), co.touchlab.kermit, org.kotlincrypto (SecureRandom), org.slf4j, io.appmetrica.analytics, com.google.firebase (messaging, installations, datatransport), com.google.android.gms (basement, base, tasks, ads-identifier, appset, cloud-messaging, stats), com.pairip.licensecheck
Подозрительные домены	ilgwzfpctifclvhmajht.supabase.co
SharedPreferences	файл app_prefs: isSuccess — метка, пускать ли человека на внешнюю страницу; VisibilityAuthDialog — показывали ли уже окно-предупреждение; TitleAuthDialog и DescAuthDialog — заголовок и текст этого окна, скачанные с сервера
Есть ли клоака	да
Подозрительные слова	238NEW, valiable1, stream, urlAuth, urlCheckAuth, urlSuccessAuth, urlNotOpen, urlsNotOpen, urlsNotOpenTitle, pageAuth, openAuth, isSuccess, loadUrl, shouldOverrideUrlLoading, shouldInterceptRequest, doUpdateVisitedHistory, Keycloak (в названии содержится cloak)

Проверка домена: ilgwzfpctifclvhmajht.supabase.co

Параметр / движок	Значение / вердикт
Домен	ilgwzfpctifclvhmajht.supabase.co
VirusTotal URL	https://www.virustotal.com/gui/domain/ilgwzfpctifclvhmajht.supabase.co
Детекции	0/92 (malicious=0, suspicious=0)
Security vendors' analysis	ниже построчно, как на VirusTotal
Abusix	Clean
Acronis	Clean
ADMINUSLabs	Clean
AILabs (MONITORAPP)	Clean
AlienVault	Clean
Antiy-AVL	Clean
BitDefender	Clean
Blueliv	Clean
Certego	Clean
Chong Lua Dao	Clean
CINS Army	Clean
CMC Threat Intelligence	Clean
CRDF	Clean
Criminal IP	Clean
Cyble	Clean
CyRadar	Clean
desenmascara.me	Clean
DNS8	Clean
Dr.Web	Clean
EmergingThreats	Clean
Emsisoft	Clean
ESET	Clean
ESTsecurity	Clean
Forcepoint ThreatSeeker	Clean
Fortinet	Clean
G-Data	Clean
Google Safe Browsing	Clean
GreenSnow	Clean
Heimdal Security	Clean
IPsum	Clean
Juniper Networks	Clean
Kaspersky	Clean
Lionic	Clean
Malwared	Clean
MalwarePatrol	Clean
OpenPhish	Clean
Phishing Database	Clean

Параметр / движок	Значение / вердикт
Phishtank	Clean
PREBYTES	Clean
Quick Heal	Clean
Quttera	Clean
Scantitan	Clean
SCUMWARE.org	Clean
Seclookup	Clean
Snort IP sample list	Clean
Sophos	Clean
StopForumSpam	Clean
Sucuri SiteCheck	Clean
ThreatHive	Clean
URLhaus	Clean
Viettel Threat Intelligence	Clean
ViriBack	Clean
VX Vault	Clean
Webroot	Clean
Xcitium Verdict Cloud	Clean
Yandex Safebrowsing	Clean
ZeroCERT	Clean
0xSI_f33d	Unrated
alphaMountain.ai	Unrated
AlphaSOC	Unrated
ArcSight Threat Intelligence	Unrated
AutoShun	Unrated
Axur	Unrated
Bfore.Ai PreCrime	Unrated
Bkav	Unrated
ChainPatrol	Unrated
CSIS Security Group	Unrated
CTX AI	Unrated
Cyan	Unrated
Ermes	Unrated
Fortra	Unrated
GCP Abuse Intelligence	Unrated
GreyNoise	Unrated
Gridinsoft	Unrated
Guardpot	Unrated
Hunt.io Intelligence	Unrated
LevelBlue	Unrated
Lumu	Unrated
MalwareURL	Unrated
Mimecast	Unrated

Параметр / движок	Значение / вердикт
Netcraft	Unrated
Orcapot	Unrated
PhishFort	Unrated
PrecisionSec	Unrated
SafeToOpen	Unrated
Sansec eComscan	Unrated
SecureBrain	Unrated
SOCRadar	Unrated
Synthient	Unrated
URLQuery	Unrated
VIPRE	Unrated
ZeroFox	Unrated
Куда редиректит	нет (без редиректа)
Что выводит (кратко)	{"error":"requested path is invalid"}
Где припаркован	регистратор: GANDI SAS

Какие данные собираются

- ключ доступа к базе настроек
- название таблицы настроек
- запрос всех столбцов таблицы
- название схемы базы
- название и версия сетевой библиотеки
- метка «проверку уже прошёл» из памяти приложения
- наличие подключения к интернету
- адреса страниц, открываемых во встроенном окне сайта

Как собираются

Сразу при запуске открывается заставка, и уже на ней приложение само, без каких-либо вопросов к человеку, тянет из интернета таблицу настроек и складывает её в свою внутреннюю базу на телефоне. Делает это класс LoadRepoImpl, который вызывается с экрана заставки (SplashFragment и его SplashViewModel), так что человек видит только логотип и крутящуюся загрузку. Вместе с запросом уходит только служебное: ключ доступа к базе, имя таблицы, пометка «отдай все столбцы», имя схемы базы и название самой сетевой библиотеки. Отдельно приложение смотрит в свою память (файл app_prefs) на метку isSuccess — это внутренний признак «этого человека уже проводили по внешней странице» — и проверяет у системы, есть ли вообще интернет. Важный факт по коду: для этой проверки приложение не читает ни язык телефона, ни модель, ни рекламный номер, ни страну — таких обращений в своём коде нет. Позже, когда внешняя страница уже открыта во встроенном окне сайта, приложение дополнительно читает адреса всех страниц, по которым человек переходит, и сверяет их со списками, пришедшими с сервера. Отдельно от этой схемы в приложении работает библиотека статистики AppMetrica: она включается в самой первой строке запуска (класс App) со своим ключом и собирает сведения об устройстве по своим правилам, но к проверке «кому что показать» она не подключена.

Куда отправляются

Запрос уходит тихо, в фоне, на адрес https://ilgwzfpctifclvhmajht.supabase.co — это чужая база данных, созданная на сервисе Supabase, а не сайт самого «Фонбета». Приложение обращается к таблице с именем 238NEW и просит все её строки целиком (в коде это видно как обращение from(supabaseClient, «238NEW») и параметр select=*). Полный адрес запроса собирается библиотекой: к адресу базы добавляется служебный путь /rest/v1/ и имя таблицы, а ключ доступа подставляется из строки, зашитой прямо в коде приложения. Запасных адресов в приложении нет — адрес базы ровно один и он жёстко прописан в классе DataModule. Всё, что пришло в ответ, приложение сохраняет у себя на телефоне: ссылки и тексты кладутся в собственную базу (app_database), а заголовок и описание предупреждающего окна дублируются в память приложения (app_prefs). После этого при следующих запусках приложение берёт данные уже из своей памяти и повторно в интернет за ними не ходит. Отдельно, уже для самой спортивной части, приложение общается с сервисом api-sports.io — это обычная выдача расписания и счёта матчей, к показу внешней страницы она не относится.

Как фильтруются пользователи

Решение «показать внешнюю страницу или оставить обычное приложение» принимает сервер, но очень простым способом: он либо кладёт в таблицу ссылку, либо оставляет это поле пустым. В приложении нет ни списка стран, ни проверки языка, ни проверки на эмулятор или робота — никаких признаков человека на проверку оно не отправляет, поэтому на стороне телефона фильтра как такового нет. На телефоне остаётся только два условия: ссылка в ответе должна быть непустой и внутренняя метка isSuccess должна быть включена (по умолчанию она включена, а выключается навсегда после того, как человека один раз провели по внешней странице). Зато после открытия внешней страницы в приложении работает собственная фильтрация самих адресов: пришедший с сервера список urlsNotOpen — это куски адресов, которые запрещено открывать, и при попытке на них уйти приложение возвращает человека назад и показывает всплывающее окно с текстом, тоже скачанным с сервера. Второй список, urlCheckAuth, и отдельная строка urlSuccessAuth — это, наоборот, признаки «нужное действие выполнено»: как только адрес страницы содержит такой кусок, приложение гасит метку isSuccess и уводит человека в обычное приложение. Ещё одна строка, urlNotOpen, при точном совпадении возвращает человека на предыдущий экран. То есть все правила «кого куда пускать» приходят с сервера списками, а приложение их просто исполняет.

Что возвращается

Сервер отвечает не одной ссылкой, а набором строк таблицы: у каждой строки есть номер (id), текстовое поле valiable1 и поле-список stream. Приложение разбирает ответ строго по номерам: из строки 8 берётся главная ссылка (в коде она называется urlAuth), из строки 1 — заголовок предупреждающего окна, из строки 2 — его описание, из строки 3 — заголовок всплывающего окна о запрещённом адресе, из строки 6 — адрес, который нельзя открывать, из строки 7 — признак «действие выполнено», а из строк 4 и 5 — два списка кусков адресов (запрещённые и, наоборот, означающие успех). Главный признак для приложения — именно ссылка из строки 8: если она пришла непустой и внутренняя метка ещё не погашена, приложение считает, что человека можно вести на внешнюю страницу. Если же эта строка пустая или таблица пришла пустой, никакого внешнего перехода не будет. Если сеть или сервер не ответили, экран заставки показывает короткое сообщение «Возникла ошибка. Попробуйте позже». Никакого «да/нет», счёта или готового текста страницы сервер не присылает — только эти поля.

Как показывается оффер или белая версия

Если ссылка пришла, то сразу после заставки человек попадает не в приложение, а на пустой экран с одной большой красной кнопкой «Регистрация / Войти». Нажатие на кнопку открывает ту самую ссылку с сервера внутри приложения, во встроенном окне сайта:

отдельный браузер телефона не запускается, адресной строки нет, поэтому со стороны это выглядит как собственный экран приложения. Окно настроено максимально «по-браузерному»: включены скрипты, хранение данных сайта, всплывающие окна и автозапуск видео. Сам адрес в APK не зашит — он приходит с сервера, поэтому точный сайт по файлу приложения назвать нельзя; по смыслу экрана и по текстам приложения («для информации о ставках на реальные деньги посетите наш официальный сайт») это страница регистрации у букмекера, то есть целевое рекламное действие, а не обычный рекламный баннер. Пока человек ходит по этой странице, приложение следит за адресами и может вернуть его назад с предупреждением либо, увидев нужный адрес, закрыть окно сайта и больше его не показывать. Если же ссылки в ответе нет или метка уже погашена, никакой внешней страницы не возникает: человеку просто остаётся обычное приложение.

Пояснение по подозрительному домену

ilgwzfpctifclvhmajht.supabase.co — это личная база данных на облачном сервисе Supabase, адрес и ключ доступа к ней зашиты в код приложения. Именно оттуда приложение на старте забирает ссылку на внешнюю страницу и списки адресов, по которым потом решает, куда человека пускать, а куда нет. По проверке VirusTotal домен чистый (0 детекций из 92), сам по себе он безопасен и при прямом открытии отдаёт только служебный ответ {"error":"requested path is invalid"}. Опасность не в домене, а в его роли: это пульт управления, через который владелец приложения в любой момент меняет ссылку и правила показа, не выпуская обновление в магазин.